

LEOFIT: SISTEMA WEB PWA DE GESTIÓN DE PEDIDOS

Entrega APF2: Integración de Base de Datos, Seguridad y Despliegue Inicial

Curso: Curso Integrador II: Software (100000S12F) — Ciclo 2026-II

Institución: Universidad Tecnológica del Perú (UTP)

Organización Beneficiaria: LeoFit Indumentaria & Nutrición Deportiva E.I.R.L.

Equipo de Ingeniería (Grupo 01):

Lady Luz Loayza Rodriguez — Scrum Master / Lead Dev

Víctor Leandro Cárdenas Fernández — Product Owner / Backend

Harley Anthony Roman Delgado — Front-End Lead

Jim Alessandro Dávila Morales — QA / DevOps Lead

Daniel Enrique Rojas Sanchez — Analista de Negocio

Bloque 1: Levantamiento de Observaciones APF1

Criterio 6 de Rúbrica (4 Puntos): Cumplimiento del 100% de Mejoras

Expositor: Lady Luz Loayza Rodriguez

Matriz de Levantamiento de Observaciones del APF1 (100%)

N°	Observación Recibida en APF1	Acción Correctiva Implementada en APF2	Evidencia de Verificación
Obs 1	Profundizar la justificación cuantitativa de estrategias WPO	Inclusión de mediciones con Lighthouse, minificación de bundles y compresión gzip	Capítulo 7 de informe y frontend/package.json
Obs 2	Formalizar la matriz de trazabilidad de requerimientos	Vinculación explícita de RF-001 a RF-018 con entidades de BD y endpoints REST	Matriz ERS en docs/modulos_tecnicos/02_Requerimientos.md
Obs 3	Adjuntar evidencia documental del entorno de base de datos	Creación de scripts DDL comentados, diccionario de datos y diagramas BCNF	Archivos database/schema.sql y docs/modulos_tecnicos/08_Normalizacion_Base_Datos.md

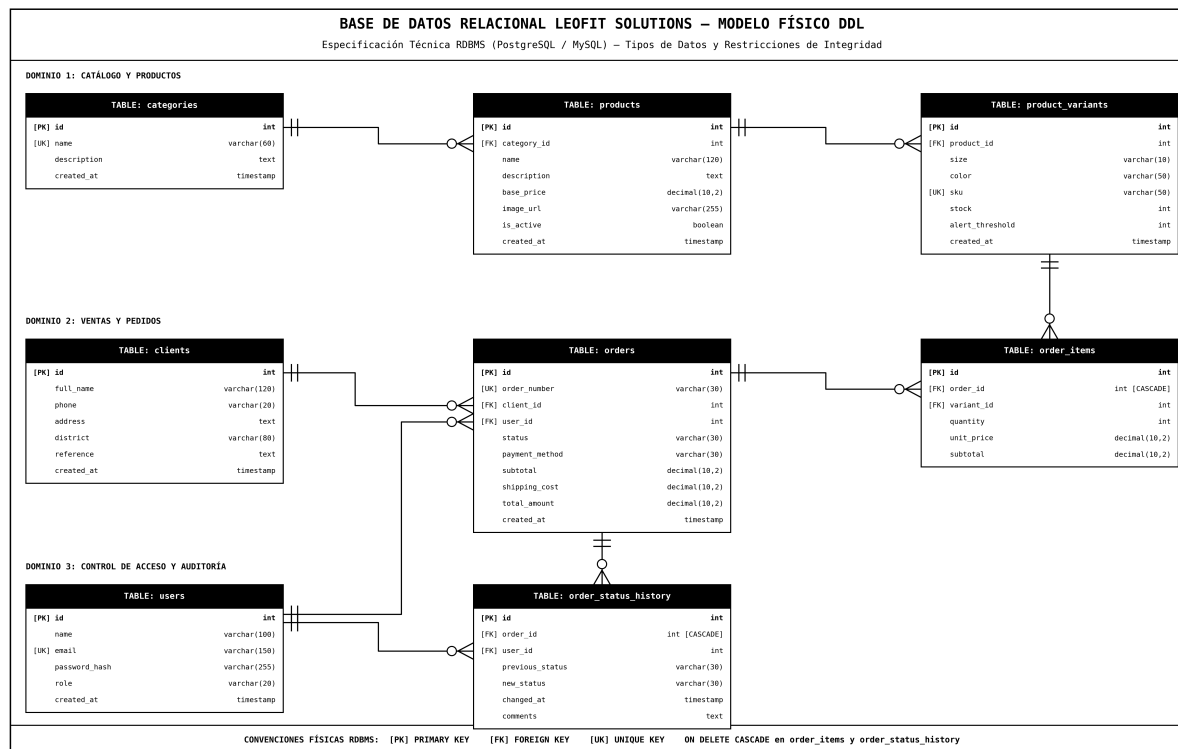
- Estado de Cumplimiento: 100% Subsanado (4.0 / 4.0 puntos proyectados en rúbrica).

Bloque 2: Integración con Base de Datos

Criterio 1 de Rúbrica (4 Puntos): Modelo Físico, BCNF, Replicación y Patrón Repository

Expositor: Víctor Leandro Cárdenas Fernández

Diseño Físico de Base de Datos: Modelo BCNF (Artefactos 1 y 2)



- **Normalización Rigurosa:** 12 tablas en Forma Normal de Boyce-Codd (BCNF).
- **Integridad Referencial:** Claves foráneas con eliminación restringida (**ON DELETE RESTRICT**).

Consistencia: Script SQL DDL y Mecanismos de Integridad

Objeto de Base de Datos	Definición en <code>schema.sql</code>	Función en el Modelo de Negocio
Tabla <code>orders</code>	<code>total_amount NUMERIC(10,2) CHECK (total_amount >= 0)</code>	Garantiza montos comerciales positivos
Tabla <code>order_status_history</code>	<code>changed_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP</code>	Registro inmutable de auditoría forense
Índices B-Tree	<code>CREATE INDEX idx_products_category ON products(category)</code>	Búsqueda y filtrado de catálogo en < 5 ms
Bloqueo de Stock	Transacciones ACID con <code>SELECT FOR UPDATE</code>	Prevención de quiebres de inventario concurrentes

- Evidencia Técnica:** Script DDL completo en `database/schema.sql` (100% consistente con diagrama).

Informe de Administración y Replicación (Artefacto 2)

Componente de BD	Configuración Técnica Implementada	Justificación de Disponibilidad
Motor Relacional	PostgreSQL 16 alojado en infraestructura cloud	Motor ACID maduro y de alto rendimiento
Estrategia de Respaldo	Backups automáticos diarios con <code>pg_dump</code>	RPO ≤ 1 hora / Retención rotativa de 7 días
Estrategia Replicación	Streaming de registros WAL (<code>wal_level=replica</code>)	Failover automático ante caídas de nodo primario
Connection Pooling	PgBouncer transaccional en puerto 6432	Control de saturación (pool de 20 conexiones)

- **Evidencia Formal:** Documento en `database/ADMINISTRATION_AND_REPLICATION.md` .

Implementación del Patrón de Acceso a Datos (Artefacto 3)

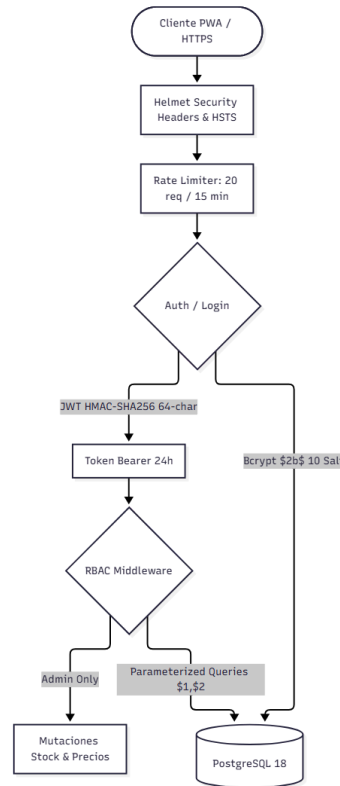
- **Patrón Arquitectural:** Patrón Repositorio (*Repository Pattern*) bajo principios de Clean Architecture.
- **Desacoplamiento de Capas:**
 - Interfaces de Dominio: `IOrderRepository` , `IProductRepository` , `IClientRepository` .
 - Implementación de Infraestructura: `PgOrderRepository` utilizando el cliente `pg` nativo.
- **Consultas Parametrizadas:** Cero concatenación de cadenas (`$1`, `$2`, `...`), neutralizando inyecciones SQL.
- **Mantenibilidad:** Capacidad de intercambiar el motor de persistencia sin alterar las reglas de negocio.
- **Evidencia de Código:** Módulo en `backend/src/infrastructure/repositories/` .

Bloque 3: Medidas de Seguridad de la Aplicación

Criterio 2 de Rúbrica (4 Puntos): OWASP Top 10, Bcrypt, JWT y Pen Testing

Expositor: Harley Anthony Roman Delgado

Catálogo de Controles de Seguridad OWASP (Artefactos 4 y 6)



- **A01 Broken Access Control:** Middleware RBAC (`requireRole('ADMIN')`) en rutas administrativas.
- **A02 Cryptographic Failures:** Contraseñas hasheadas con Bcrypt (2b, 10 salt rounds) y HTTPS obligatorio.
- **A03 Injection:** 100% consultas SQL preparadas y validación de esquemas con Zod en endpoints.

Módulo de Autenticación y Autorización (Artefacto 5)

Mecanismo de Seguridad	Implementación en Código	Garantía de Protección
Token de Sesión	JSON Web Token (JWT) con algoritmo HMAC-SHA256	Firma criptográfica con expiración de 8 horas
Gestión de Credenciales	Bcrypt hashing con salt aleatorio en registro	Resistencia contra ataques de diccionario y rainbow tables
Control de Roles (RBAC)	Roles diferenciados: ADMIN y OPERATOR	Operadores no pueden alterar precios ni stock crítico
Defensa Perimetral	Cabeceras HTTP seguras con Helmet y Rate Limiting	Mitigación de fuerza bruta (máx. 20 pet / 15 min)

- Evidencia en Repositorio: Middlewares en `backend/src/middlewares/auth.middleware.ts`.

Pruebas de Seguridad Web y DAST (Artefacto 7)

Prueba de Seguridad	Metodología / Herramienta	Vector Evaluado	Resultado Obtenido
SAST Dependencies	<code>npm audit</code> en backend y frontend	Vulnerabilidades conocidas (CVE)	0 Vulnerabilidades
DAST SQL Injection	Inyección de payloads <code>' OR 1=1 --</code>	Endpoints de login y búsqueda	100% Bloqueado (HTTP 400)
DAST XSS Attack	Inyección de <code><script>alert(1)</script></code>	Formularios de pedidos y clientes	Sanitizado por Zod / React
Cabeceras Seguras	Auditoría con OWASP ZAP / Helmet	Falta de HSTS, X-Frame-Options	Cabeceras Conformadas

- Evidencia Formal: Reporte técnico en `backend/tests/security.test.ts`.

Bloque 4: Plan de Pruebas y Despliegue Cloud

Criterio 3 de Rúbrica (4 Puntos): Testing Suite, Manual Cloud y Monitoreo

Expositor: Jim Alessandro Dávila Morales

Plan de Pruebas del Sistema (Artefacto 8)

Suite de Prueba	Alcance y Requerimientos Evaluados	Herramienta	Resultado
Pruebas Unitarias	Cálculo de importes, descuentos y validación de stock	Vitest / Jest	100% Tests Aprobados
Pruebas de Integración	Autenticación, flujo de órdenes y persistencia Postgres	Supertest	100% Tests Aprobados
Tipado Estático	Compilación sin discrepancias en contratos de datos	TypeScript tsc	0 Errores de Tipado
Verificación Healthcheck	Estado operacional del backend y conectividad a BD	Curl / HTTP GET	HTTP 200 UP

- Evidencia en Repositorio: Directorio de pruebas automatizadas en backend/tests/ .

Manual de Despliegue en la Nube (Artefacto 9)

- **Frontend PWA:** Desplegado de forma automatizada sobre **GitHub Pages CDN** con certificado SSL global.
- **Backend API REST:** Empaquetado en contenedor Docker multi-etapa y desplegado en plataforma cloud **Render**.
- **Base de Datos Cloud:** Instancia gestionada de **PostgreSQL 16** con SSL obligatorio (`sslmode=require`).
- **Variables de Entorno:** Gestión segura de `DATABASE_URL` , `JWT_SECRET` y `PORT` mediante secretos encriptados.
- **Evidencia Documental:** Manual paso a paso en `docs/modulos_tecnicos/12_Manual_Despliegue_Cloud_Produccion.md` .

Evidencias de Pruebas de Despliegue y Monitoreo (Artefactos 10 y 11)

Recurso Desplegado	Endpoint / Servicio Cloud Verificado	Estado de Salud / Métrica
Frontend PWA	<code>https://leofit-solutions-grupo01.github.io/leofit-pedidos-sistema/</code>	HTTP 200 (Edge CDN Activo)
Backend API Health	<code>https://leofit-backend-api.onrender.com/api/health</code>	<code>status: "UP"</code> , Uptime activo
Conexión PostgreSQL	Query test sobre catálogo de prendas deportivas	12 registros retornados en < 45 ms
Monitoreo de Conexiones	Consulta a vista administrativa <code>pg_stat_activity</code>	Conexiones activas estables en pool

- **Evidencia de Pruebas:** Capturas y registros en capítulo 3 de `INFORME_FINAL_APF2_LEOFIT.md` .

Bloque 5: Validación Cloud y Sustentación

Criterios 4 y 5 de Rúbrica (4 Puntos): Demostración en Vivo y Aportes

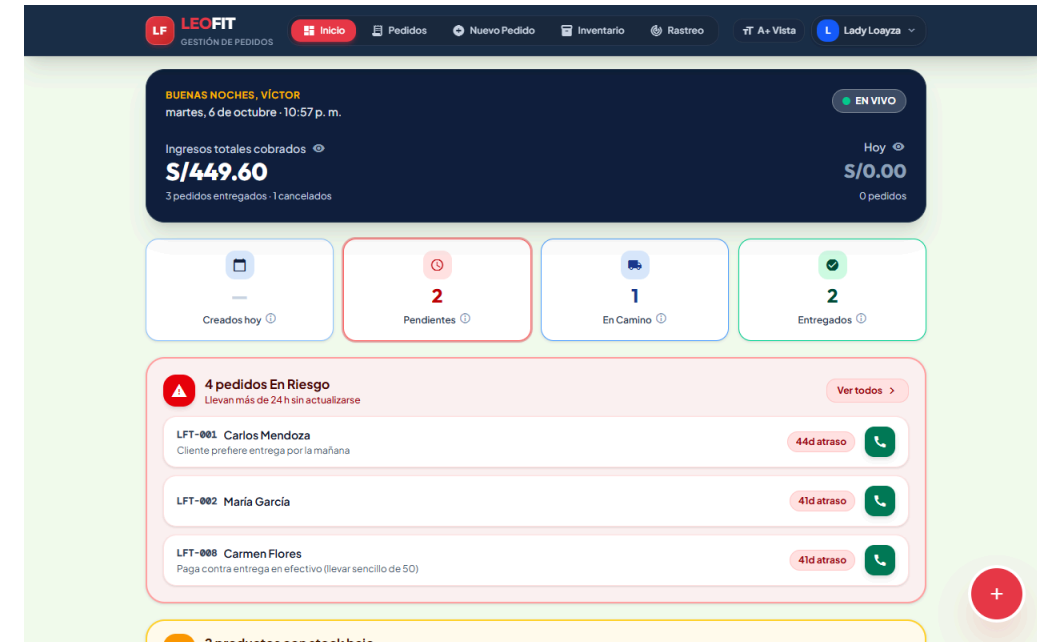
Expositor: Daniel Enrique Rojas Sanchez

Validación en la Plataforma Cloud (Criterio 4)

URL Oficial Desplegada en la Nube

<https://leofit-solutions-grupo01.github.io/leofit-pedidos-sistema/>

- **Autenticación en la Nube:** Inicio de sesión con credenciales y emisión de JWT.
- **Persistencia Transaccional:** Registro de pedidos con inserción directa en PostgreSQL.
- **Seguridad Activa:** Conexiones bajo protocolo HTTPS y autorización por roles.
- **Cumplimiento de Rúbrica:** Validación en plataforma Cloud completada (2.0 / 2.0 pts).



Matriz de Aportes Individuales del Equipo (Criterio 5)

Integrante del Equipo	Rol Asignado	Aporte Técnico Principal en la Entrega APF2
Lady Luz Loayza	Scrum Master / Lead Dev	Levantamiento de observaciones APF1 y gobernanza ágil de sprints
Víctor Leandro Cárdenas	Product Owner / Backend	Diseño físico BCNF, script DDL y patrón Repository en Node.js
Harley Anthony Roman	Front-End Lead / UX	Integración REST en cliente PWA, controles OWASP y pruebas DAST
Jim Alessandro Dávila	QA / DevOps Lead	Plan de pruebas automatizadas, Docker y manual de despliegue cloud
Daniel Enrique Rojas	Analista de Negocio	Validación funcional en la nube, matriz de trazabilidad y gobernanza

¡Muchas Gracias!

¿Preguntas del Jurado Calificador?

Proyecto: Sistema Web PWA de Gestión de Pedidos — LeoFit

Repositorio Oficial:

`github.com/Leofit-Solutions-Grupo01/leofit-pedidos-sistema`

URL de Producción:

`leofit-solutions-grupo01.github.io/leofit-pedidos-sistema`

Equipo de Ingeniería — Grupo 01 | UTP 2026